Cheatsheet AZ-104 — 13 · Seguridad de red: NSG y ASG, reglas efectivas, Bastion, service endpoints y private endpoints

1. Network Security Groups

Propiedad de una regla	Valores
Priority	**100-4096**; se evalúan de **menor a mayor** y la primera que coincide **detiene** la evaluación; no puede haber dos con la misma prioridad y dirección
Source / Destination	Any, IP o CIDR, **varias IPs** (augmented), **service tag** (VirtualNetwork, Internet, AzureLoadBalancer, AzureCloud, Storage, Storage.WestEurope, Sql, AzureKeyVault, AzureBastion, GatewayManager, AzureMonitor...) o **application security group**
Protocol	TCP, UDP, ICMP, ESP, AH, Any
Port	Uno, rango o lista (`80,443,8000-8010`)
Direction	Inbound / Outbound
Action	Allow / Deny

Regla por defecto	Prioridad	Qué hace
AllowVnetInBound	65000	Permite todo lo que venga del tag **VirtualNetwork** (la VNet, las **VNets emparejadas** y **on-prem** vía gateway)
AllowAzureLoadBalancerInBound	65001	Permite las **sondas** del balanceador (168.63.129.16)
DenyAllInBound	65500	Deniega el resto (incluido **internet**)
AllowVnetOutBound	65000	Salida a la VNet
AllowInternetOutBound	65001	Salida a **internet** permitida por defecto
DenyAllOutBound	65500	Deniega el resto

- No se borran, pero se **sobrescriben** con reglas de menor número. Para "deny all outbound internet" → regla Deny a Internet con prioridad < 65001 (y Allow a los service tags necesarios).
- **Asociación:** un NSG a **subredes** y/o **NICs** (una subred o NIC solo tiene **un** NSG; un NSG sirve a muchas). Debe estar en la **misma región** (y suscripción) que la VNet. Límite **2 000 reglas** por NSG.
- **Evaluación** cuando hay NSG en subred **y** en NIC: entrante → **primero el de la subred, luego el de la NIC**; saliente → **primero la NIC, luego la subred**. El tráfico debe estar permitido en **ambos**. El NSG de la subred también filtra el tráfico **entre VMs de la misma subred**.
- **Stateful:** una regla Inbound permite las respuestas; no hace falta la Outbound (y viceversa). Cambiar reglas solo afecta a **conexiones nuevas**. Las sondas del LB y los servicios de plataforma (DHCP, DNS, IMDS en 168.63.129.16 / 169.254.169.254) no se bloquean salvo con tags específicos. Puerto **25** saliente bloqueado salvo en suscripciones EA / MCA-E (usar relay SMTP). **ICMP** no está permitido desde internet por defecto.

2. Application Security Groups

- Agrupan **NICs** por función (web, app, db) y se usan como **origen o destino** de reglas NSG: "Allow TCP 1433 from asg-web to asg-db". Una NIC puede estar en **varios** ASGs; todas las NICs de un ASG deben estar en la **misma VNet**, y si una regla usa dos ASGs, ambos en la misma VNet. Permiten reglas estables aunque cambien las IPs o se añadan VMs.

3. Interpretar reglas efectivas (lo que cae con tablas)

Situación	Resultado	Por qué
NSG de NIC permite RDP desde internet; NSG de subred no tiene regla	**Bloqueado**	En la subred gana DenyAllInBound; hacen falta los dos
NSG de subred permite RDP; la NIC no tiene NSG	Permitido	Solo se evalúa el de la subred
Regla 100 Allow 3389 desde Any; regla 110 Deny 3389 desde Any	**Permitido**	Gana la de menor número
Regla 100 Deny 3389 desde Internet; regla 200 Allow 3389 desde 203.0.113.0/24	Bloqueado para todos	La 100 coincide primero (Internet incluye esa IP): invertir prioridades
VM1 y VM2 en subredes distintas de la misma VNet, sin reglas personalizadas	Se ven	AllowVnetInBound
Backend del LB marcado unhealthy tras un NSG nuevo	Se bloqueó AzureLoadBalancer / 168.63.129.16	Añadir Allow desde el tag AzureLoadBalancer al puerto de la sonda
Regla Deny Any → Internet saliente con prioridad 100	Las VMs no actualizan ni llegan a Storage	Añadir Allow a los tags (Storage, AzureMonitor...) con número de prioridad menor, o service endpoints
VM en VNet emparejada no puede acceder	NSG con origen limitado a la subred local	VirtualNetwork incluye las VNets emparejadas; revisar reglas personalizadas

- **Effective security rules** (NIC → Networking) muestra la suma de subred + NIC; **IP flow verify** dice qué regla permite o deniega un flujo concreto; **NSG diagnostics** evalúa todos los NSGs del camino (cheatsheet 12). Los **flow logs** (VNet flow logs; los NSG flow logs se retiran en sept. 2027) registran aceptado / denegado por regla.

4. Azure Bastion

Aspecto	Detalle
Qué es	RDP / SSH a VMs **por el portal (HTML5, puerto 443)** o con cliente nativo, sin **IP pública** en las VMs ni abrir 3389 / 22 a internet
Requisitos	Subred `AzureBastionSubnet` **/26 o mayor** (misma VNet y RG), IP pública **Standard estática**; llega a VMs de la VNet y de las **VNets emparejadas** (un Bastion en el hub); la VM necesita regla NSG que permita 3389 / 22 desde la subred de Bastion (el tag VirtualNetwork lo cubre)
NSG en AzureBastionSubnet	Entrada: 443 desde **Internet**, 443 desde **GatewayManager**, 443 desde **AzureLoadBalancer**, 8080 y 5701 desde VirtualNetwork · Salida: 3389 y 22 a VirtualNetwork, 443 a **AzureCloud**, 8080 y 5701 a VirtualNetwork, 80 a Internet
Developer	Gratis, sin subred dedicada, una conexión a la vez, solo portal; para dev/test
Basic	2 instancias; portal; VNets emparejadas; Kerberos
Standard	**Host scaling** (2-50 instancias), **cliente nativo** (mstsc / ssh / `az network bastion rdp`), **transferencia de ficheros**, **shareable links**, conexión por **IP** (on-prem vía VPN), puertos personalizados
Premium	Además **session recording** y despliegue **private-only** (sin IP pública)

- "Users must connect with their own RDP client through Bastion" → Standard. "Record RDP sessions for audit" → Premium. "Bastion deployment fails on /27" → la subred debe ser /26.

5. Service endpoints vs private endpoints

	Service endpoint	Private endpoint (Private Link)
Qué hace	Extiende la **identidad de la subred** al servicio; el tráfico sale con **IP privada** de origen por el backbone hacia el **endpoint público** del servicio	Crea una **NIC con IP privada** de tu subred que representa al recurso (blob, sqlServer, vault, sites...); el servicio queda accesible como si estuviera en la VNet
Se configura en	La **subred** (`Microsoft.Storage`, `Microsoft.Sql`, `Microsoft.KeyVault`, `Microsoft.Web`, `Microsoft.ServiceBus`, `Microsoft.EventHub`, `Microsoft.AzureCosmosDB`, `Microsoft.ContainerRegistry`...) + **regla de VNet** en el firewall del recurso	El **recurso** (sub-resource) + subred donde vive la NIC + **zona DNS privada** `privatelink.<servicio>`
DNS	No cambia (resuelve a IP pública)	Debe resolver a la **IP privada**: zona `privatelink.*` enlazada a las VNets (y reenvío desde on-prem con **DNS Private Resolver**)
Desde on-prem	**No** (el tráfico on-prem llega con IPs públicas NAT → regla de IP)	**Sí**, por VPN / ExpressRoute
Desde VNets emparejadas	Cada subred activa su endpoint	Sí (el peering alcanza la IP privada; enlazar la zona DNS a esa VNet)
Endpoint público	Sigue existiendo (se restringe con el firewall)	Se puede **desactivar** del todo ("public network access disabled")
Coste	Gratis	Por hora y por GB
Granularidad	Toda la cuenta / servidor; **endpoint policies** (Storage) para limitar a cuentas concretas	Un recurso y sub-recurso concreto; aprobación automática o manual
Cuándo	Rápido y barato para "solo desde mi VNet"	"No public endpoint", "from on-premises", "private IP", "zero trust"

Servicio	Zona privada
Blob / File / Queue / Table / DFS / Web (static)	`privatelink.blob.core.windows.net` · `privatelink.file.core.windows.net` · `privatelink.queue...` · `privatelink.table...` · `privatelink.dfs...` · `privatelink.web...`
Azure SQL Database	`privatelink.database.windows.net`
Key Vault	`privatelink.vaultcore.azure.net`
App Service	`privatelink.azurewebsites.net`
Container Registry	`privatelink.azurecr.io`

- Al activar un service endpoint, las conexiones existentes se cortan y las reglas de IP pública para esa subred dejan de funcionar (ahora llega con IP privada). Para **Azure SQL** el endpoint solo sirve en la **misma región**; Storage tiene `Microsoft.Storage.Global` para otras regiones.
- Private endpoint y NSG: las **network policies** del private endpoint se pueden activar en la subred para aplicar NSG / UDR al tráfico hacia la NIC del endpoint. Para exponer **tu propio** servicio detrás de un ILB Standard a otros tenants → **Private Link service**.

6. Otras capas

Servicio	Para qué	Frente a NSG
Azure Firewall	Firewall gestionado, stateful, centralizado en el hub (`AzureFirewallSubnet` /26): reglas de **red**, de **aplicación por FQDN**, **DNAT**, threat intelligence, Premium con IDPS y TLS inspection; **Firewall Policy** y Firewall Manager	NSG filtra por IP / puerto en subred o NIC; Firewall inspecciona y centraliza (todo el tráfico llega vía **UDR**)
DDoS Protection	Network Protection (toda la VNet) o IP Protection (por IP pública); mitigación automática	—
Just-in-time VM access (Defender for Cloud)	Abre 3389 / 22 **solo bajo petición** y durante un tiempo, creando la regla NSG temporal	"reduce exposure of management ports"
Virtual Network Manager: security admin rules	Reglas globales que se evalúan **antes** que los NSGs (Allow, Always allow, Deny)	Gobernanza central

Servicio	Para qué	Frente a NSG
Web Application Firewall	En Application Gateway / Front Door (capa 7, OWASP)	Cheatsheet 14

7. Comandos que caen

Tarea	PowerShell (Az.Network)	Azure CLI
Crear NSG y regla	`$r = New-AzNetworkSecurityRuleConfig -Name AllowRDP -Priority 100 -Direction Inbound -Access Allow -Protocol Tcp -SourceAddressPrefix 203.0.113.0/24 -SourcePortRange * -DestinationAddressPrefix * -DestinationPortRange 3389; New-AzNetworkSecurityGroup -Name nsg1 -ResourceGroupName RG1 -Location westeurope -SecurityRules $r`	`az network nsg create -g RG1 -n nsg1` · `az network nsg rule create -g RG1 --nsg-name nsg1 -n AllowRDP --priority 100 --direction Inbound --access Allow --protocol Tcp --source-address-prefixes 203.0.113.0/24 --destination-port-ranges 3389`
Regla con tag o ASG	`-SourceAddressPrefix AzureLoadBalancer` · `-SourceApplicationSecurityGroupId <asg-web> -DestinationApplicationSecurityGroupId <asg-db>`	`--source-address-prefixes AzureLoadBalancer` · `--source-asgs asg-web --destination-asgs asg-db`
Modificar / listar reglas	`$nsg = Get-AzNetworkSecurityGroup -Name nsg1 -ResourceGroupName RG1; Set-AzNetworkSecurityRuleConfig -NetworkSecurityGroup $nsg -Name AllowRDP -Access Deny ...; Set-AzNetworkSecurityGroup -NetworkSecurityGroup $nsg` · `Get-AzNetworkSecurityRuleConfig -DefaultRules`	`az network nsg rule update -g RG1 --nsg-name nsg1 -n AllowRDP --access Deny` · `az network nsg rule list -g RG1 --nsg-name nsg1 --include-default -o table`
Asociar	Subred: `Set-AzVirtualNetworkSubnetConfig ... -NetworkSecurityGroup $nsg; Set-AzVirtualNetwork` · NIC: `$nic.NetworkSecurityGroup = $nsg; Set-AzNetworkInterface`	`az network vnet subnet update -g RG1 --vnet-name vnet1 -n sub1 --network-security-group nsg1` · `az network nic update -g RG1 -n nic1 --network-security-group nsg1` · quitar: `--network-security-group ""`
ASG	`New-AzApplicationSecurityGroup -Name asg-web -ResourceGroupName RG1 -Location westeurope` · en la NIC: `$nic.IpConfigurations[0].ApplicationSecurityGroups = @($asg); Set-AzNetworkInterface`	`az network asg create -g RG1 -n asg-web` · `az network nic ip-config update -g RG1 --nic-name nic1 -n ipconfig1 --application-security-groups asg-web`
Reglas efectivas	`Get-AzEffectiveNetworkSecurityGroup -NetworkInterfaceName nic1 -ResourceGroupName RG1`	`az network nic list-effective-nsg -g RG1 -n nic1`
Bastion	`New-AzBastion -ResourceGroupName RG1 -Name bas1 -PublicIpAddressRgName RG1 -PublicIpAddressName pip-bas -VirtualNetworkRgName RG1 -VirtualNetworkName vnet1 -Sku Standard -ScaleUnit 4`	`az network vnet subnet create -g RG1 --vnet-name vnet1 -n AzureBastionSubnet --address-prefixes 10.0.255.0/26` · `az network bastion create -g RG1 -n bas1 --vnet-name vnet1 --public-ip-address pip-bas --sku Standard --scale-units 4 --enable-tunneling true`
Service endpoint	`Set-AzVirtualNetworkSubnetConfig ... -ServiceEndpoint Microsoft.Storage,Microsoft.Sql; Set-AzVirtualNetwork` + `Add-AzStorageAccountNetworkRule -VirtualNetworkResourceId <subnet id>`	`az network vnet subnet update -g RG1 --vnet-name vnet1 -n sub1 --service-endpoints Microsoft.Storage Microsoft.Sql` + `az storage account network-rule add -n st1 --vnet-name vnet1 --subnet sub1`
Private endpoint	`New-AzPrivateEndpoint -Name pe-st1 -ResourceGroupName RG1 -Location westeurope -Subnet $subnet -PrivateLinkServiceConnection (New-AzPrivateLinkServiceConnection -Name c1 -PrivateLinkServiceId <st id> -GroupId blob)` + `New-AzPrivateDnsZone -Name privatelink.blob.core.windows.net` + `New-AzPrivateDnsVirtualNetworkLink` + `New-AzPrivateDnsZoneGroup`	`az network private-endpoint create -g RG1 -n pe-st1 --vnet-name vnet1 --subnet sub1 --private-connection-resource-id <st id> --group-id blob --connection-name c1` · `az network private-dns zone create -g RG1 -n privatelink.blob.core.windows.net` · `az network private-dns link vnet create -g RG1 -z privatelink.blob.core.windows.net -n link1 -v vnet1 -e false` · `az network private-endpoint dns-zone-group create -g RG1 --endpoint-name pe-st1 -n zg --private-dns-zone privatelink.blob.core.windows.net --zone-name blob`

8. Árbol de decisión

```
¿Qué pide el enunciado?
├─ Filtrar por IP / puerto en una subred o NIC ..... NSG (recordar que subred y NIC deben permitir)
├─ Reglas por rol de servidor sin IPs ..... Application security groups
├─ Saber qué regla bloquea un flujo ..... IP flow verify / NSG diagnostics
├─ RDP / SSH sin IP pública ni VPN ..... Azure Bastion (cliente nativo, ficheros → Standard)
├─ Abrir RDP solo cuando se pide y por un rato ..... Just-in-time VM access
├─ PaaS accesible solo desde mi VNet, gratis, rápido ..... Service endpoint + VNet rule
├─ PaaS sin endpoint público, acceso desde on-prem ..... Private endpoint + zona privatelink + DNS
├─ PaaS accesible desde una VNet emparejada por IP privada ..... Private endpoint + enlace de la zona a esa VNet
├─ Filtrado por FQDN, inspección, DNAT centralizado ..... Azure Firewall (hub + UDR)
├─ Proteger IPs públicas de DDoS ..... DDoS Network / IP Protection
├─ Exponer mi servicio a otro tenant por IP privada ..... Private Link service (ILB Standard)
└─ Ver tráfico denegado ..... VNet flow logs + Traffic analytics
```

9. Señales → respuesta

Enunciado	Respuesta
"RDP allowed on the NIC NSG but still blocked"	El NSG de la subred lo deniega: permitir en ambos
"rule 100 allows, rule 200 denies"	Gana la 100 (menor número)
"allow web tier to reach database tier on 1433, servers change often"	ASGs + regla NSG
"load balancer backend unhealthy after adding NSG"	Permitir AzureLoadBalancer (168.63.129.16) al puerto de la sonda
"block all outbound internet but allow Azure Storage"	Deny Internet + Allow service tag Storage con número de prioridad menor (o service endpoint)

Enunciado	Respuesta
"VMs in peered VNet blocked"	VirtualNetwork cubre el peering; revisar reglas personalizadas
"NSG can be applied to a VNet"	Falso: solo subred o NIC
"RDP without public IP from the portal"	Bastion
"Bastion needs native RDP client / file copy / shareable link"	Standard
"session recording"	Premium
"AzureBastionSubnet /27 error"	Mínimo /26
"storage only from subnet, no cost"	Service endpoint Microsoft.Storage + regla de VNet
"storage not reachable from on-premises after service endpoint"	Esperado: añadir IP pública NAT de on-prem o usar private endpoint
"SQL private endpoint resolves to public IP"	Falta la zona `privatelink.database.windows.net` enlazada a la VNet (o DNS custom sin reenvío)
"private endpoint from on-premises"	VPN / ExpressRoute + DNS Private Resolver inbound (o forwarder)
"disable public access to the storage account"	Public network access Disabled + private endpoint
"inspect outbound traffic by FQDN"	Azure Firewall (application rules)
"management ports exposed", "reduce attack surface"	JIT VM access

10. Errores a evitar

1. Olvidar que entre NSG de subred y NIC gana el deny de cualquiera.
2. Poner la regla Deny con menor número que el Allow específico (o al revés) sin pensar en el orden.
3. Bloquear 168.63.129.16 / AzureLoadBalancer y romper las sondas, DHCP o DNS.
4. Asociar un NSG a una VNet (no se puede) o de otra región.
5. Crear la subred de Bastion con otro nombre o con /27.
6. Esperar que un service endpoint funcione desde on-prem o cambie el DNS.
7. Crear el private endpoint sin la zona DNS privada enlazada a todas las VNets que lo usan.
8. Elegir NSG cuando piden filtrado por FQDN o inspección centralizada (Azure Firewall).